

Anexo - Ciberseguridad



”Porque el club es de los socios, y la gestión es de SocioUnido”

Plataforma inteligente que centraliza la gestión administrativa de los clubes, optimizando el uso de espacios compartidos, previniendo la morosidad y asegurando los accesos al estadio.

Alumno	Correo electrónico	Padrón
Ascencio, Felipe Santino	fascencio@fi.uba.ar	110675
Ghosn, Lautaro Gabriel	lghosn@fi.uba.ar	106998
Guerrero, Martín	mguerrero@fi.uba.ar	107774
Zielonka, Axel	azielonka@fi.uba.ar	110310

Jefe de Cátedra Mg. Ing. Carlos Fontela cfontela@fi.uba.ar

Tutor Mg. Ing. Gabriel Piñeiro gpineiro@fi.uba.ar

Cotutor Ing. Agustín Perrotta aperrotta@fi.uba.ar

Índice

1. Ciberseguridad	3
1.1. Protección proactiva de dependencias: Implementación de Dependabot	3
1.2. Inspección y calidad centralizada: El rol estratégico de SonarCloud	4
1.2.1. Reportes generados por SonarCloud	5

1. Ciberseguridad

La ciberseguridad y la integridad estructural del código fuente representan pilares no negociables en la arquitectura de SocioUnido. Dado que la plataforma opera como un ecosistema integral de gestión para clubes de fútbol, procesando flujos financieros (cobro de cuotas, venta de entradas), información personal sensible del padrón de socios (PII) y gestionando controles de acceso físicos masivos, cualquier vulnerabilidad o fallo arquitectónico podría resultar en fugas de capital, interrupciones operativas severas o daños reputacionales irreparables para las instituciones.

Para garantizar la máxima fiabilidad a todos los niveles, el ciclo de vida del desarrollo de software de SocioUnido incorpora un enfoque proactivo de DevSecOps. Este paradigma trasciende la simple revisión manual, implementando herramientas de análisis estático, escaneo continuo de dependencias y monitoreo centralizado de calidad, asegurando que la seguridad sea un atributo inherente desde la fase de codificación hasta el despliegue en producción.

1.1. Protección proactiva de dependencias: Implementación de Dependabot

En el ecosistema moderno de desarrollo de software, especialmente en arquitecturas basadas en microservicios, los proyectos dependen de una vasta y compleja red de librerías y paquetes de terceros (el *Supply Chain* de software). Estas dependencias, fundamentales para la agilidad del desarrollo, son frecuentemente el vector de ataque principal para la inyección de vulnerabilidades conocidas (CVEs - *Common Vulnerabilities and Exposures*).

Para mitigar este riesgo de forma automatizada, la organización de GitHub de SocioUnido integra **Dependabot** en la totalidad de sus repositorios de desarrollo. La vitalidad de esta herramienta reside en su capacidad para actuar como un auditor de seguridad continuo e incansable:

- **Monitoreo continuo:** Dependabot escanea ininterrumpidamente los manifiestos de dependencias (tales como `Gemfile.lock`, `package-lock.json`, o `requirements.txt` dependiendo del microservicio) cruzando las versiones utilizadas contra bases de datos globales de vulnerabilidades actualizadas en tiempo real.
- **Resolución automatizada:** Al detectar que un microservicio de SocioUnido (por ejemplo, el módulo de Pagos o el de Autenticación) está utilizando una versión de una librería con una brecha de seguridad pública, Dependabot no solo alerta al equipo, sino que genera automáticamente un *Pull Request* (PR) proponiendo la actualización exacta a la versión mínima segura. Esto reduce el tiempo medio de remediación (MTTR) de días a horas.
- **Mantenimiento de la estabilidad:** Al combinarse con nuestra integración continua (CI), cada PR generado por Dependabot dispara automáticamente la batería de pruebas unitarias y de integración. Esto garantiza que la actualización de seguridad no rompa la lógica de negocio ni genere regresiones, permitiendo al equipo fusionar (*merge*) el parche con total confianza.

1.2. Inspección y calidad centralizada: El rol estratégico de SonarCloud

Mientras que Dependabot audita el código de terceros, la integridad, seguridad y mantenibilidad del código *propio* desarrollado por el equipo requiere un análisis de caja blanca de extrema profundidad. Para este propósito, SocioUnido ha integrado **SonarCloud** como su motor principal de Análisis Estático de Código (SAST) y control de calidad.

La implementación de SonarCloud es vital para el proyecto por tres motivos fundamentales:

1. **Detección Temprana de Vulnerabilidades Lógicas y *Security Hotspots*:** Durante el flujo de Integración Continua (activado vía GitHub Actions en cada *commit* o *Pull Request*), SonarCloud analiza el código en busca de patrones peligrosos, fallos de inyección (SQLi, XSS), exposición accidental de credenciales o lógicas criptográficas débiles. Al identificar un riesgo, bloquea el despliegue mediante un *Quality Gate* fallido, impidiendo que el código vulnerable llegue al entorno de producción.
2. **Control de Deuda Técnica y *Code Smells*:** Más allá de la seguridad pura, el sistema evalúa la mantenibilidad del software. Identifica código duplicado, lógicas excesivamente complejas (alta complejidad ciclomática) y desviaciones de los estándares de la industria (*code smells*). Esto cuantifica la “deuda técnica” en horas de remediación, permitiendo al equipo de desarrollo priorizar la refactorización y mantener un código base limpio y escalable, fundamental para la posterior integración con los sistemas físicos de los estadios.
3. **Trazabilidad a través del Repositorio .github:** La arquitectura descentralizada de SocioUnido (múltiples microservicios, frontends, APIs) presenta el desafío de la fragmentación de la información. Para resolver esto, hemos configurado un repositorio central especial denominado .github. Este repositorio actúa como la **torre de control y visualización centralizada** del proyecto. Mediante archivos README dinámicos y tableros integrados en .github, el equipo expone los *badges* (insignias) y reportes consolidados de SonarCloud para *todos* los repositorios involucrados. Esta vista panorámica es invaluable, ya que permite a cualquier miembro del equipo (o auditor externo) verificar de un vistazo el estado global de salud del ecosistema completo, así como profundizar en las métricas particulares (Bugs, Vulnerabilidades, Cobertura de Tests) de un microservicio específico sin necesidad de navegar por múltiples paneles aislados.

En conclusión, la sinergia entre el escaneo de dependencias (Dependabot), la auditoría profunda de código fuente (SonarCloud) y la orquestación centralizada (repositorio .github) conforma una barrera de defensa profunda. Esta metodología exhaustiva garantiza que la plataforma SocioUnido no solo responda eficientemente a las necesidades funcionales de los clubes, sino que lo haga sobre cimientos arquitectónicos resilientes, auditables y ciberseguros.

1.2.1. Reportes generados por SonarCloud

Métricas de actividad (Commits, Pull Requests e Issues)

Repositorio	Commits	Pull Requests	Issues abiertos
Aplicación	commit activity 18/week	pull requests 0 open	issues 3 open
Bitácora	commit activity 4/week	pull requests 0 open	issues 1 open
Control de accesos	commit activity 18/week	pull requests 0 open	issues 1 open
Documentación	commit activity 17/week	pull requests 0 open	issues 22 open
Gateway	commit activity 10/week	pull requests 0 open	issues 1 open
Healthchecker	commit activity 6/week	pull requests 0 open	issues 2 open
Ideas de producto	commit activity 5/week	pull requests 0 open	issues 0 open
MS Acceso	commit activity 8/week	pull requests 0 open	issues 1 open
MS Analíticas	commit activity 9/week	pull requests 0 open	issues 1 open
MS Autenticación	commit activity 3/week	pull requests 0 open	issues 2 open
MS Bot Conversacional	commit activity 11/week	pull requests 0 open	issues 4 open
MS Club	commit activity 25/week	pull requests 0 open	issues 5 open
MS Pagos	commit activity 5/week	pull requests 0 open	issues 1 open
Plataforma web	commit activity 31/week	pull requests 0 open	issues 7 open
Scrum	commit activity 22/week	pull requests 0 open	issues 2 open
.github	commit activity 6/week	pull requests 0 open	issues 0 open

Figura 1: Métricas de actividad: Control de Commits, Pull Requests e Issues abiertos en el ecosistema de repositorios.

Reporte de estado (Quality Gate, bugs, seguridad, deuda técnica y duplicación de código)

Repositorio	Quality Gate	Confiabilidad (Bugs)	Seguridad	Deuda técnica	Duplicación
Aplicación	quality gate failed	bugs 0	security C	technical debt 39min	duplicated lines 0.3%
Bitácora	quality gate failed	bugs 0	security C	technical debt 0	duplicated lines 0%
Control de accesos	quality gate failed	bugs 0	security C	technical debt 26min	duplicated lines 0%
Documentación	quality gate failed	bugs 0	security C	technical debt 11min	duplicated lines 0%
Gateway	quality gate passed	bugs 0	security C	technical debt 0	duplicated lines 0%
Healthchecker	quality gate passed	bugs 0	security E	technical debt 12min	duplicated lines 0%
Ideas de producto	quality gate failed	bugs 0	security C	technical debt 0	duplicated lines 0%
MS Acceso	quality gate passed	bugs 0	security C	technical debt 10min	duplicated lines 0%
MS Analíticas	quality gate passed	bugs 0	security C	technical debt 15min	duplicated lines 0%
MS Autenticación	quality gate passed	bugs 0	security E	technical debt 50min	duplicated lines 0%
MS Bot Conversacional	quality gate failed	bugs 0	security E	technical debt 10min	duplicated lines 0%
MS Club	quality gate passed	bugs 0	security E	technical debt 2h	duplicated lines 0.2%
MS Pagos	quality gate passed	bugs 0	security C	technical debt 15min	duplicated lines 0%
Plataforma Web	quality gate passed	bugs 5	security A	technical debt 4d	duplicated lines 0%
Scrum	quality gate failed	bugs 0	security C	technical debt 0	duplicated lines 0%
.github	quality gate failed	bugs 0	security C	technical debt 0	duplicated lines 0%

Figura 2: Reporte de estado: Quality Gate, conteo de bugs, métricas de seguridad, deuda técnica y duplicación de código.